Symmetric Encryption on the Domain Controller

Home lab guide: Kerberos AES · SMB3 share encryption · department keys

A beginner's step-by-step guide for the home MacBook Air. About 2 hours. Every script explains what it does, saves its output for the report, and tells you when to take a screenshot.

Project	Healthcare IAM Operations Simulation — Horizon Valley Medical Center (HVMC)
Topic	Cryptography 1 — Symmetric Cryptography, add-on lab on the domain controller (the rubric report of 13 Oct is unchanged)
Prepared By	Sabitha S Karanavar
Version	1.0 — November 3, 2026
Where	Home MacBook Air (VirtualBox): `hvmc-dc01` 192.168.56.10 and `hvmc-client01` 192.168.56.11
Kit	GitHub: `cryptography_1/symmetric_on_dc/` — downloaded straight onto the VMs in Step 3 (no zip, no kit password)
Cost	$0 — no Azure

Part	What you will do	Why it matters
1. Kerberos	Make the domain controller issue sign-in tickets with **AES only** and refuse the old **RC4** cipher	RC4 tickets can be cracked offline (Kerberoasting); AES is the modern standard
2. File shares	Turn on **SMB3 encryption (AES)** for the Week 5 department shares	Without it, files on the EHR share cross the network readable
3. Department keys	Give each department its own **AES-256 key**, readable only by its AD group, using **your own AES code** from 13 Oct; rotate a key	Even with the file, a nurse or a Finance user cannot read Doctors data

Part 0 — Before you start

You need	Notes
Both VMs: **HVMC-DC01** and **HVMC-CLIENT01**	This lab uses the client too (unlike Rubric 6)
Your VM login for the DC, and the `ubuntu` password for the client	Week 1 and Week 2 documents

You need	Notes
The lab practice password for **sarah.chen** (Doctors) and **brian.adeyemi** (Finance)	Typed at prompts only — never saved by the scripts
Internet for the VMs (Adapter 1, NAT)	To download the kit from GitHub and install tcpdump/tshark
Recommended: finish Rubric 6 first	Then its evidence is already captured before these settings change

> **Safety rules.** (1) Take the snapshots in Step 1 first — if anything goes wrong you restore them. (2) Every change to `smb.conf` is backed up, checked, and rolled back automatically if Samba does not start; each part also has an `undo`. (3) The only data in the tests is fictional and marked `HVMC-DEMO-NOTE`. (4) Never paste a real password into a script or a file.

Part A — Get ready (20 minutes)

VirtualBox Step 1 — Take safety snapshots of both VMs

If the VMs are running, shut them down cleanly (`sudo poweroff` in each). In VirtualBox take a snapshot of **HVMC-DC01** and of **HVMC-CLIENT01**, both named **before symmetric redo**. Start the **DC first** (Start → Headless Start), wait 1 minute, then start the client the same way.

📸 **Screenshot:** the two snapshot lists

MAC Terminal Step 2 — Open two Terminal windows: DC and CLIENT

In Terminal press ⌘**N** for a second window. In the first, log in to the DC; in the second, log in to the client. If you finished Rubric 6, the DC login is the SSH key alias `ssh hvmc-dc01`; otherwise use your VM username.

```
ssh hvmc-dc01                    # DC window (or: ssh YOURNAME@192.168.56.10)
ssh ubuntu@192.168.56.11         # CLIENT window
```

DC window CLIENT window Step 3 — Download the kit from GitHub (in BOTH windows)

These commands download only this lab's folder and your AES code from 13 Oct. If it says `git: command not found`, run `sudo apt-get install -y git` first. If the folder already exists, use `cd ~/hvmc_repo && git pull`.

```
cd ~
git clone --depth 1 --filter=blob:none --sparse https://github.com/sabi-s/dae-6-month-Sabi.git hvmc_repo
cd hvmc_repo && git sparse-checkout set cryptography_1/symmetric_on_dc cryptography_1/symmetric_crypto
cd cryptography_1/symmetric_on_dc && chmod +x dc/*.sh client/*.sh && ls
```

✔ **You should see:** `client dc tools README.md HVMC_Symmetric_on_DC_Home_Lab_Guide.pdf`

DC window **Step 4 — DC precheck**

Checks Samba, the Week 5 shares and the domain users, and installs tcpdump and tshark if missing (needs your VM password).

```
cd ~/hvmc_repo/cryptography_1/symmetric_on_dc/dc
./00_precheck.sh
```

✔ **You should see:** Samba 4.19, the EHR share, `id HVMC\sarah.chen` with *sg-doctors-ehr-rw*, and ✅ **Precheck passed**

📸 **Screenshot:** this window

CLIENT window **Step 5 — Client precheck**

Checks the domain join and lists the encryption types of the client's own Kerberos keys (asks for the ubuntu password).

```
cd ~/hvmc_repo/cryptography_1/symmetric_on_dc/client
./c0_precheck.sh
```

✔ **You should see:** `configured: kerberos-member`, the keytab types (aes256-cts…, aes128-cts…) and ✅ **Precheck passed**

📸 **Screenshot:** this window

Part B — Kerberos: AES only, RC4 off (25 minutes)

For each capture: start it in the **DC window** (it waits), run the client test in the **CLIENT window**, then press **Enter** in the DC window when the client says **Done**.

DC window **Step 6 — What the KDC allows today**

```
./01_kerberos_aes.sh show
```

✔ **You should see:** `kdc supported enctypes` = **0** (Samba default: RC4 and AES allowed)

📸 **Screenshot:** this window

DC window CLIENT window **Step 7 — Capture 1: Kerberos BEFORE the change**

The client signs in normally, then pretends to be an old client that only speaks RC4. You type Sarah's password (twice).

```
./03_capture.sh krb_before     # DC window - it waits
./c1_kerberos.sh before        # CLIENT window
(press Enter in the DC window)
```

✔ **You should see:** CLIENT: ✅ **Normal sign-in uses AES-256** and ✅ **… the domain controller still hands out RC4 tickets (weak)**; DC: ✅ **Captured N packets**

📸 **Screenshot:** the CLIENT window (klist -e with aes256, then the RC4 ticket)

DC window Step 8 — Switch RC4 off

Adds `kdc supported enctypes = 24` (AES-128 + AES-256) and restarts Samba. If Samba does not start, the backup is put back automatically.

```
./01_kerberos_aes.sh apply
```

✔ **You should see:** value **0** before, **24** after, and ✅ **KDC now allows AES only**

📸 **Screenshot:** this window

DC window CLIENT window Step 9 — Capture 2: Kerberos AFTER the change

```
./03_capture.sh krb_after      # DC window
./c1_kerberos.sh after         # CLIENT window
(press Enter in the DC window)
```

✔ **You should see:** CLIENT: ✅ **Normal sign-in uses AES-256** and ✅ **RC4 refused … KDC has no support for encryption type**

📸 **Screenshot:** the CLIENT window with the RC4 refusal

Part C — Encrypt the department shares, SMB3 (25 minutes)

DC window Step 10 — Share encryption today

```
./02_smb_encrypt.sh show
```

✔ **You should see:** each share under /srv/shares with `server smb encrypt = default`

📸 **Screenshot:** this window

DC window CLIENT window Step 11 — Capture 3: file traffic BEFORE

Sarah writes and reads a fictional note in the EHR share. The connection stays open for 12 seconds so the DC can record it.

```
./03_capture.sh smb_before     # DC window
./c2_smb.sh before             # CLIENT window
(press Enter in the DC window)
```

✔ **You should see:** CLIENT: `putting file …`, the `ls` listing and ✅ **Sarah can still write and read in EHR**

DC window Step 12 — Require encryption

Adds `server smb encrypt = required` to every department share and reloads Samba (no restart). Permissions are not changed.

```
./02_smb_encrypt.sh apply
```

✔ **You should see: default** before, **required** after

📸 **Screenshot:** this window

DC window CLIENT window **Step 13 — Capture 4: file traffic AFTER**

Same test, now encrypted. Then two extra checks: an old SMB 2.1 client (cannot encrypt) is refused, and Brian (Finance) is still refused on EHR — you type Brian's password once.

```
./03_capture.sh smb_after      # DC window
./c2_smb.sh after              # CLIENT window
(press Enter in the DC window)
```

✔ **You should see:** CLIENT: ✅ **Sarah can still write and read**, ✅ **SMB 2.1 … refused**, ✅ **Brian (Finance) refused: NT_STATUS_ACCESS_DENIED**; DC: `smbstatus` showing **SMB3_11** and an **AES-…-GCM/CCM** value in the Encryption column

📸 **Screenshot:** the DC smbstatus output and the CLIENT results

Part D — One key per department (20 minutes)

DC window **Step 14 — Department keys with your AES code**

Installs `dept_vault.py` with your `aes.py` and `key_management.py` to /opt/hvmc-vault, creates an AES-256 key for **Doctors** and **Finance** (each readable only by its AD group), encrypts one fictional record each (envelope encryption: a new data key per record, wrapped by the department key), and runs the tests as the real domain users.

```
./04_dept_keys.sh
```

✔ **You should see:** T1 Sarah opens Doctors ✅ · T2 Brian refused Doctors key ✅ · T3 Brian opens Finance ✅ · T4 Sarah refused Finance key ✅ · T5 tampered record refused ✅ · T6 Doctors key rotated v1 → v2, old key destroyed ✅ · T7 Sarah still opens it ✅ — **Results: 12 passed, 0 failed**

📸 **Screenshot:** the key ACLs, T1–T5, and the rotation with T7 (the script tells you when)

Part E — Analyse, collect, Wireshark (25 minutes)

DC window **Step 15 — Analyse the four captures**

```
./05_analyze.sh
```

✔ **You should see:** krb_before: an AS-REP that *uses rc4-hmac*; krb_after: **KDC_ERR_ETYPE_NOSUPP**; smb_before: the note text found N times; smb_after: **0 times** and *Encrypted SMB3* packets

📸 **Screenshot:** the summary and the two ✅ lines

DC window CLIENT window **Step 16 — Pack the evidence**

No passwords, tickets or key files go into the packages (the DC script checks).

```
./06_collect.sh                # DC window
./c3_collect.sh                # CLIENT window
```

✔ **You should see:** ✅ **Packed ~/symdc_evidence_dc.tar.gz** and ✅ **Packed ~/symdc_evidence_client.tar.gz**

MAC Terminal Step 17 — Bring the evidence to the Mac

Open a third Terminal window (⌘N) on the Mac itself.

```
mkdir -p ~/Desktop/HVMC_SymDC_Evidence/screenshots && cd ~/Desktop/HVMC_SymDC_Evidence
scp hvmc-dc01:symdc_evidence_dc.tar.gz .        # or
YOURNAME@192.168.56.10:symdc_evidence_dc.tar.gz
scp ubuntu@192.168.56.11:symdc_evidence_client.tar.gz .
mkdir dc client && tar -xzf symdc_evidence_dc.tar.gz -C dc && tar -xzf
symdc_evidence_client.tar.gz -C client
```

✔ **You should see:** the two .tar.gz files and the folders `dc` and `client` in HVMC_SymDC_Evidence on your Desktop

Open in Wireshark (Desktop → HVMC_SymDC_Evidence → dc → symdc_evidence → pcaps)	What to do	What it shows
`krb_before.pcap`	Filter `kerberos`; click the last *AS-REP* → Kerberos → enc-part → etype	**eTYPE-ARCFOUR-HMAC-MD5 (23)**: the DC handed out an RC4-protected reply
`krb_after.pcap`	Filter `kerberos`; click the *KRB Error*	**KRB5KDC_ERR_ETYPE_NOSUPP**: RC4 refused; normal sign-ins use eTYPE-AES256-CTS-HMAC-SHA1-96 (18)
`smb_before.pcap`	Filter `smb2`; right-click a *Write Request* → Follow → TCP Stream	The fictional note `HVMC-DEMO-NOTE … Jane Testcase` readable on the network
`smb_after.pcap`	Filter `smb2`; look at the Info column	**Encrypted SMB3** after the session set-up: no file names, no text
`smb_after.pcap`	Statistics → Protocol Hierarchy	Everything after set-up is the SMB2 transform (encrypted) header

VirtualBox Step 18 — Finish

Put your screenshots into `screenshots` in HVMC_SymDC_Evidence. Right-click the folder → **Compress**, and email `HVMC_SymDC_Evidence.zip` to yourself. Shut both VMs down and take snapshots named **symmetric redo done**. At the office, tell Claude: "*the symmetric redo evidence is in Downloads*".

Screenshot checklist

✓	Step	Screenshot	Shows
□	1	Both snapshot lists	Safe change practice
□	4, 5	DC and client prechecks	Lab ready; client keytab already AES
□	6, 8	kdc supported enctypes 0 → 24	Kerberos hardened to AES
□	7	klist -e with aes256, RC4 ticket accepted	The weakness before
□	9	RC4 refused: KDC has no support for encryption type	The fix works
□	10, 12	server smb encrypt default → required	Share encryption configured
□	13	smbstatus Encryption column; SMB 2.1 and Brian refused	Encrypted, permissions unchanged
□	14	Key ACLs, T1–T5, rotation and T7	Per-department keys and rotation
□	15	Analysis summary	Before/after proof
□	17	Five Wireshark views from the table	Protocol analysis

If something goes wrong

Problem	What to do
Samba does not start after Step 8	The script puts the backup back by itself. To remove the setting later: `./01_kerberos_aes.sh undo`.
Something old stops working after Step 8 (it needed RC4)	Note what it was (that is a finding for the report), then `./01_kerberos_aes.sh undo`.
A share stops working after Step 12	`./02_smb_encrypt.sh undo` and send Claude `~/symdc_evidence/logs/02_smb_encrypt.txt`.
`git clone` fails	The VM needs internet through Adapter 1 (NAT). Test with `ping -c2 github.com`; try again in a minute.
`kinit: Preauthentication failed`	Wrong password for that user - run the client step again.
A capture says it is empty	Start the DC capture first, then run the client command while the DC window is waiting.
Step 14: domain users not visible to sudo	The script switches to a temporary identity that holds only the department group; the tests still mean the same.
Anything else	Stop, restore the *before symmetric redo* snapshots if needed, and bring the logs in `~/symdc_evidence/logs` on each VM.

Words you will see

Word	Meaning
Kerberos / KDC	The domain's sign-in system. The KDC on hvmc-dc01 hands out encrypted tickets that prove who you are.
Encryption type (etype)	Which cipher protects a ticket: 18 = AES-256, 17 = AES-128, 23 = RC4 (old and weak).
SMB3 encryption	AES encryption of everything sent between a computer and a file share (AES-128-GCM or CCM).
KEK / DEK	Key-encryption key (one per department) and data-encryption key (a new one per record). The KEK wraps the DEK.
Key rotation	Replacing a key with a new one on a schedule; old records are re-wrapped and the old key is destroyed.
ACL	Access control list on a file or folder: here it lets only one AD group read a department's key.